HAFTA 2 RAPORU

```
┌──(kali㉿kali)-[~]
└─$ john --format=raw-md5 --wordlist=ders_sozluk.txt ekip_md5.txt
john --format=raw-md5 --show ekip_md5.txt
Using default input encoding: UTF-8
Loaded 8 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8
x3])
No password hashes left to crack (see FAQ)
?:abc123
?:sunshine
?:trustno1
?:123456789
?:monkey
?:password
?:istanbul34
?:letmein

8 password hashes cracked, 0 left
```

```
┌──(kali㉿kali)-[~]
└─$ john --format=bcrypt --wordlist=ders_sozluk.txt ekip_bcrypt.txt
Using default input encoding: UTF-8
Loaded 8 password hashes with 8 different salts (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
trustno1         (?)
123456789        (?)
monkey           (?)
abc123           (?)
letmein          (?)
sunshine         (?)
password         (?)
istanbul34       (?)
8g 0:00:00:01 DONE (2026-10-06 10:58) 7.207g/s 21.62p/s 135.1c/s 135.1C/s mas
ter..trabzon61
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

┌──(kali㉿kali)-[~]
└─$ john --format=bcrypt --show ekip_bcrypt.txt
?:abc123
?:sunshine
?:trustno1
?:123456789
?:monkey
?:password
?:istanbul34
?:letmein

8 password hashes cracked, 0 left
```

```
┌──(kali㉿kali)-[~]
└─$ john --test --format=raw-md5
john --test --format=raw-sha256
john --test --format=bcrypt
Benchmarking: Raw-MD5 [MD5 256/256 AVX2 8×3]... DONE
Raw:    97922K c/s real, 98374K c/s virtual

Will run 2 OpenMP threads
Benchmarking: Raw-SHA256 [SHA256 256/256 AVX2 8x]... (2xOMP) DONE
Raw:    48682K c/s real, 24362K c/s virtual

Will run 2 OpenMP threads
Benchmarking: bcrypt ("$2a$05", 32 iterations) [Blowfish 32/64 X3]... (2xOMP) DONE
Speed for cost 1 (iteration count) of 32
Raw:    3276 c/s real, 1653 c/s virtual
```

Soru 5.1

Soru: Aynı sekiz parolanın MD5, SHA-256 ve bcrypt özetlerini kırdınız. Üçünde de süre ve deneme hızı nasıldı? Adım 4'teki sayılarla açıklayın.

Cevap: MD5 ve SHA-256 algoritmalarında sistem saniyede sırasıyla ~97.9 milyon ve ~48.7 milyon parola deneme hızına ulaşmıştır. Bu algoritmalar hızlı veri doğrulaması için geliştirildiğinden işlemci üzerinde çok az maliyetle hesaplanır ve sözlükteki 8 parola milisaniyeler içinde çözülmüştür. bcrypt ise bünyesindeki hesaplama maliyeti (cost/work factor) sebebiyle saniyede yalnızca ~3.276 deneme hızında kalmıştır. Kırma işlemi esnasında anlık hız 135.1 c/s seviyesine kadar gerilemiştir. Bu durum, bcrypt'in MD5'e oranla on binlerce kat daha yavaş çalışarak kaba kuvvet ve sözlük saldırılarına karşı donanım tabanlı direnç sağladığını göstermektedir.

Soru 5.2

Soru: MD5 ile SHA-256 arasında kırma kolaylığı bakımından önemli bir fark gördünüz mü? SHA-256 "daha güçlü" bir özet olduğu halde parola saklama için neden hâlâ yetersiz?

Cevap: Küçük bir sözlükle yapılan denemede iki algoritma arasında pratik kırma süresi açısından belirgin bir fark gözlemlenmemiştir; ikisinde de parolalar hemen bulunmuştur. SHA-256 matematiksel çarpışma (collision) açıklarına karşı MD5'ten çok daha güvenli olsa da parola güvenliğinde asıl belirleyici kriter işlem maliyetidir. SHA-256, büyük dosyaları hızlıca özetlemek üzere tasarlandığından geciktirici bir maliyet faktörü içermez. Bir saldırgan saniyede on milyonlarca SHA-256 özeti türetebildiği için bu algoritma parola saklamada kaba kuvvet saldırılarına karşı yetersiz kalmaktadır.

Soru 5.3

Soru: bcrypt'in yavaşlığı normal kullanıcıya (giriş yaparken) ne kadar zaman kaybettirir, saldırgana ne kadar? Bu neden iyi bir denge?

Cevap: Sisteme tek bir kez giriş yapan meşru bir kullanıcı için bcrypt doğrulaması yaklaşık 100–300 milisaniye sürer. Bu gecikme insan algısı sınırında kaldığı için kullanıcı deneyimini olumsuz etkilemez. Ancak 10 milyon parolanın yer aldığı bir listeyi kırmaya çalışan bir saldırgan için parola başına 0.2 saniye harcamak, toplam saldırı süresini yaklaşık 2 milyon saniyeye (~23 gün) çıkarır. Dolayısıyla bcrypt, sıradan kullanıcıya hiçbir yük getirmezken toplu parola denemesi yapan saldırganın zaman maliyetini pratikte imkânsız kılacak düzeye taşır.

Soru 5.4

Soru: Üç listede de aynı parolalar vardı. Gerçek bir sızıntıda iki kullanıcının MD5 özeti aynı çıkarsa bu ne anlama gelir? Tuz (salt) bunu nasıl önler?

Cevap: İki kullanıcının tuzsuz MD5 özetinin aynı olması, her iki kullanıcının da birebir aynı parolayı belirlediğini gösterir. Bu durum, saldırganın önceden hesaplanmış tablolarla (Rainbow Table) tek bir özeti çözerek birden fazla hesabı aynı anda ele geçirmesine imkan tanır. Tuz (Salt) ise her kullanıcıya özel rastgele üretilen benzersiz bir veridir ve özetleme öncesinde parolaya eklenir ($Hash(Parola + Tuz)$). Aynı parolayı seçen iki kullanıcının tuzları farklı olacağından, veritabanına yazılan özetler birbirinden tamamen farklı çıkar. Böylece Rainbow Table saldırıları engellenir ve saldırgan her parolayı tek tek kırmaya zorlanır.

İsteğe Bağlı Görev:John the Ripper Karşılaştırması

- Donanım ve Çalışma Mantığı: Hashcat sanal makinelerde GPU ve OpenCL/CUDA gereksinimi nedeniyle ek sürücüsüz çalışmaz. John the Ripper ise doğrudan işlemci (CPU) AVX2 komut setleri üzerinde ek sürücü istemeden yüksek performansla çalışmıştır.

- Komut Sözdizimi: Hashcat algoritmaları sayısal mod kodlarıyla (-m 0, -m 3200) tanımlarken, John the Ripper formatı doğrudan metin olarak (--format=raw-md5, --format=bcrypt) kabul eder.

- Çıktı ve İzleme: John the Ripper kırma işlemi esnasında anlık hız (c/s) ve durum bilgisini dinamik olarak terminale yansıtır.